

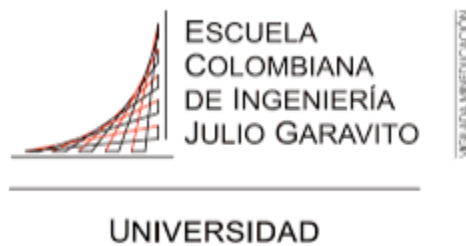
FUNDAMENTOS DE SEGURIDAD DE LA INFORMACION

LABORATORIO 2

**PRESENTADO A:
FABIAN EDUARDO SIERRA SANCHEZ**

**REALIZADO POR:
JUAN DAVID GÓMEZ CUELLAR
JOSE LUIS LANCHEROS AYORA**

1/08/2026



1. Descripción del sistema

1.1 Alcance del análisis

Este laboratorio hace un modelado de amenazas completo sobre la funcionalidad de Registro de Vehículos, que hace parte del sistema más grande de Registro de Vehículos Conectados que se trabajó en clase. Se escogió esta funcionalidad porque fue la que se explicó a fondo en el material de clase, con su arquitectura, sus operaciones de API y sus supuestos ya definidos. Esto permitió construir sobre una base ya conocida y dedicar el esfuerzo del equipo a completar el modelo de amenazas con el nivel de detalle que pide el enunciado.

1.2 Funcionalidades incluidas y excluidas

Incluidas: las cuatro operaciones que puede hacer un gestor de flota sobre los vehículos conectados, que son registrar un vehículo nuevo, darlo de baja, consultarlo y listarlos todos. También incluye la autenticación de usuarios con Amazon Cognito, el frontend web con AWS Amplify, la capa de API con Amazon API Gateway y AWS Lambda, y el almacenamiento de datos con Amazon DynamoDB y Amazon S3.

Quedan fuera del alcance, según el supuesto WCGW-07: el registro de conductores, la telemetría de viaje, los códigos de diagnóstico, la detección de anomalías y el pipeline de notificaciones. Estas funciones comparten algunos componentes de infraestructura con la que sí se analizó, como Amplify, Cognito y API Gateway, pero no se estudiaron en este laboratorio.

1.3 Actores

Internos: el equipo de backend y arquitectura de la plataforma, el equipo de infraestructura y DevOps, el equipo de seguridad e IAM, y los administradores que tienen acceso directo a los recursos de AWS.

Externos: el gestor de flota, que usa un navegador web para registrar, consultar, listar y dar de baja los vehículos de su flota.

1.4 Activos que deben protegerse

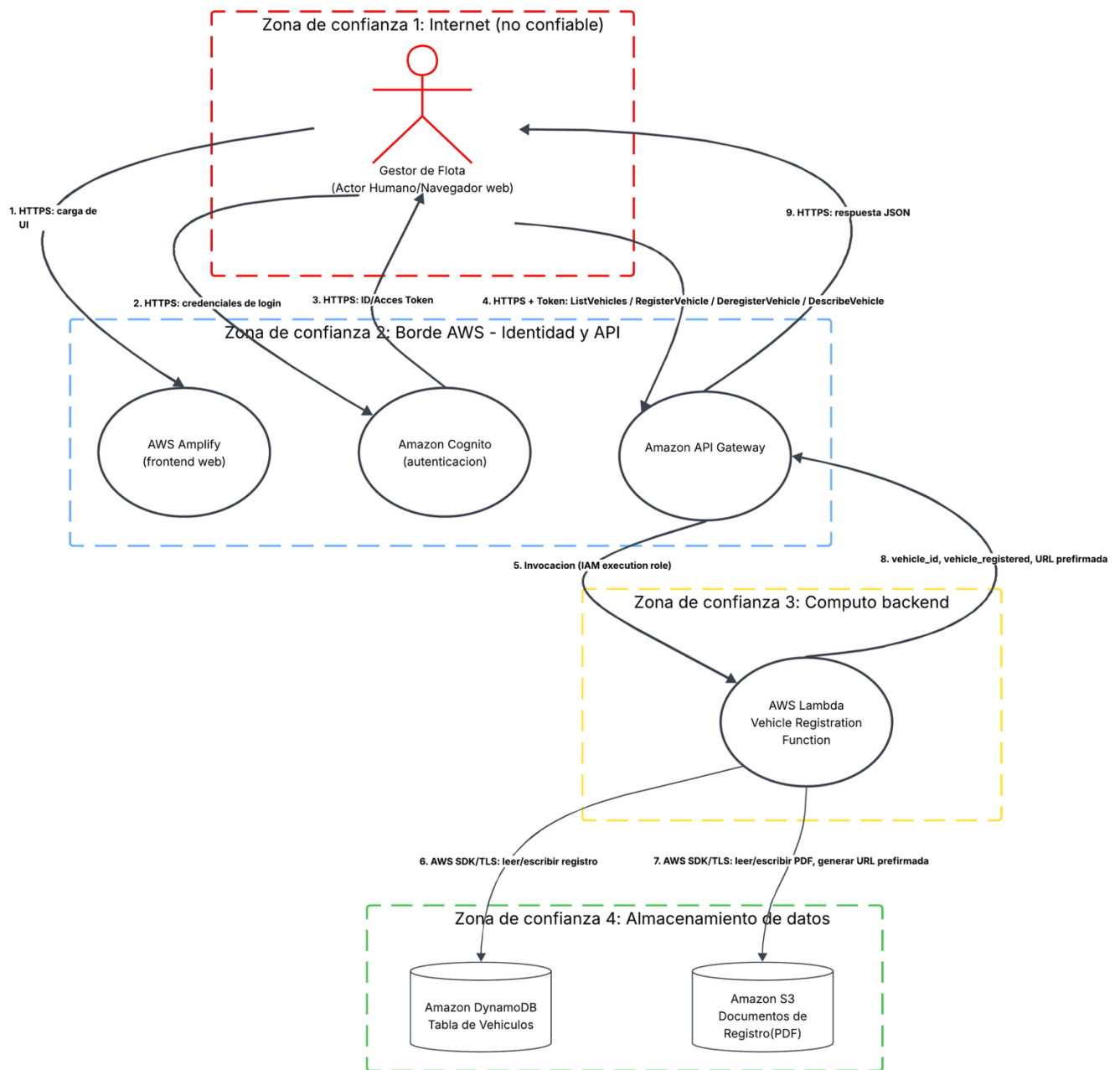
- Los registros de vehículos guardados en la tabla de DynamoDB: su identificador, tipo, número de registro y estado.
- Los documentos PDF de registro vehicular guardados en el bucket de S3.
- Las credenciales y tokens de sesión emitidos por Amazon Cognito.
- La disponibilidad de las cuatro operaciones de la API para los gestores de flota legítimos.
- La integridad del modelo de autorización, es decir, que quede claro qué usuario puede ejecutar cada operación.

1.5 Dependencias y servicios utilizados

El sistema usa AWS Amplify para alojar el frontend, Amazon Cognito para autenticar a los usuarios, Amazon API Gateway para exponer las cuatro operaciones REST, AWS Lambda para la lógica de negocio, Amazon DynamoDB para guardar los registros de vehículos de forma estructurada, y Amazon S3 para almacenar los documentos PDF de registro.

2. Diagrama de Flujo de Datos (DFD)

El diagrama muestra cuatro zonas de confianza, más de las tres que pide el enunciado como mínimo. También muestra las entidades externas, los procesos, los almacenes de datos y los flujos de información, indicando su dirección, el protocolo que usan y qué datos transportan.



2.1 Zonas de confianza identificadas

- Zona 1 — Internet, no confiable: el navegador del gestor de flota.
- Zona 2 — Borde de AWS, identidad y API: AWS Amplify, Amazon Cognito, Amazon API Gateway.
- Zona 3 — Cómputo backend: la función AWS Lambda de la feature.

- Zona 4 — Almacenamiento de datos: la tabla de Amazon DynamoDB y el bucket de Amazon S3.

3. Matriz de supuestos

La matriz completa está en el archivo Supuestos_WWWO_WCGW.xlsx, dentro de la carpeta 02_Supuestos. Ahí cada supuesto tiene su justificación o evidencia y su estado: válido, por validar o invalidado. A continuación, se listan los enunciados.

3.1 Supuestos WWWO — What We're Working On

ID	Descripción
WWWO-01	Las APIs REST (ListVehicles, RegisterVehicle, DeregisterVehicle, DescribeVehicle) son servidas por AWS Lambda y Amazon API Gateway.
WWWO-02	Existe un único ámbito (scope) de autorización que permite acceso e interacción con las cuatro operaciones de la API.
WWWO-03	Los vehicle_id son GUID aleatorios y no secuenciales.
WWWO-04	El navegador web del Gestor de Flota está parchado y actualizado.
WWWO-05	Los servicios de AWS del diagrama están en la misma región.
WWWO-06	Los servicios de AWS del diagrama están en la misma cuenta de AWS.
WWWO-07	Una única función Lambda soporta las cuatro operaciones de la API.
WWWO-08	Existe una única tabla de Amazon DynamoDB para el registro de vehículos.
WWWO-09	Existe un único bucket de Amazon S3 para los documentos de registro (PDF).
WWWO-10	AWS Amplify, Amazon Cognito y API Gateway también se usan para la feature de registro de conductores (Driver Registration), fuera de alcance de este laboratorio.
WWWO-11	La comunicación entre el navegador del Gestor de Flota y el API Gateway está protegida por TLS.
WWWO-12	Los endpoints de la función Lambda solo aceptan conexiones seguras sobre HTTPS.
WWWO-13	Se usara cifrado en reposo (encryption at rest) para la tabla de DynamoDB.
WWWO-14	Se usara cifrado en reposo (encryption at rest) para el bucket S3.
WWWO-15	El diseño del sistema se alinea con el AWS Well-Architected Security Pillar.
WWWO-16	Los documentos PDF cargados en RegisterVehicle no son parseados por código personalizado; los bytes se escriben directamente a S3.
WWWO-17	El API Gateway y la función Lambda están en la misma zona de confianza; Lambda confía en que toda solicitud que recibe ya fue autenticada por el API Gateway y no realiza autenticación adicional.
WWWO-18	Todos los usuarios autenticados pueden, en principio, ejecutar todas las operaciones de la API (sin distinción de rol).

3.2 Supuestos WCGW — What Could Go Wrong (8)

ID	Descripción
WCGW-01	Nos enfocaremos en las amenazas del lado del cliente (customer side) del modelo de responsabilidad compartida de AWS.
WCGW-02	Se puede confiar en la funcionalidad y en las opciones de configuración de seguridad de los servicios individuales de AWS (API Gateway, Lambda, DynamoDB, S3, Cognito).
WCGW-03	AWS es responsable de proteger la infraestructura que ejecuta los servicios en la nube de AWS.
WCGW-04	Las amenazas simples son más probables que las complejas; por ejemplo, ataques automatizados desde internet son más probables que una cadena de vulnerabilidades zero-day.
WCGW-05	El equipo podría configurar incorrectamente un servicio de AWS y crear un riesgo inesperado.
WCGW-06	El código propio (in-house) del equipo es probablemente más vulnerable que las librerías de código abierto estándar de la industria, siempre que estas se mantengan actualizadas.
WCGW-07	El alcance de este laboratorio se limita a la feature de Registro de Vehículos (Vehicle Registration); quedan fuera el registro de conductores, la telemetría de viaje, los códigos de diagnóstico y la detección de anomalías.
WCGW-08	Se asume que los actores externos (gestores de flota) no actúan en colusión con actores internos que tienen acceso privilegiado a la infraestructura.

4. Amenazas identificadas (STRIDE)

Se identificaron 12 amenazas, con al menos dos por cada categoría STRIDE. Todas siguen la misma estructura de redacción vista en clase: "Un [actor], bajo [precondición], puede [acción], lo que ocasiona [impacto] y reduce la [confidencialidad/integridad/disponibilidad] del [activo]". El detalle completo, con columnas para el elemento o flujo afectado, la fuente, la precondición, la acción, el impacto y el activo, está en el archivo Amenazas_STRIDE.xlsx, dentro de la carpeta 03_Amenazas_STRIDE.

ID	Elemento/flujo	STRIDE	Enunciado de amenaza
T01	Usuario / flujo Navegador->API Gateway	S	Un actor externo, bajo la precondición de lograr que el usuario interactúe con un endpoint falso, puede interceptar solicitudes válidas de la API, lo que ocasiona la exposición de datos de registro y reduce la confidencialidad e integridad del registro de vehículos.
T02	Tabla DynamoDB	T	Un actor de amenaza, bajo permisos de IAM con privilegios excesivos, puede acceder y alterar la tabla DynamoDB, lo que ocasiona exposición o modificación de datos y reduce la confidencialidad e integridad del registro de vehículos.
T03	Bucket S3 (documentos de registro)	T	Un actor con acceso al tráfico en tránsito puede leer o modificar el documento de registro, lo que ocasiona alteración del documento y reduce la integridad y confidencialidad de los documentos de registro.
T04	Usuario / API Gateway (RegisterVehicle)	R	Un usuario autenticado que registra un vehículo puede negar haberlo hecho, lo que ocasiona disputas de facturación y reduce el no repudio de los registros de facturación.

T05	API Gateway (DescribeVehicle / ListVehicles)	I	Un usuario autenticado, bajo un ámbito de autorización compartido, puede leer información de vehículos ajenos, lo que ocasiona exposición de datos de otras flotas y reduce la confidencialidad del registro de vehículos.
T06	Función Lambda (logs de ejecución)	I	Un actor con acceso a los logs de CloudWatch puede leer datos sensibles registrados por error, lo que ocasiona exposición de información del proceso de registro y reduce la confidencialidad de los datos de la función Lambda.
T07	Tabla DynamoDB	D	Un actor que envía solicitudes concurrentes masivas puede agotar la capacidad de la tabla, lo que ocasiona fallos en las cuatro operaciones y reduce la disponibilidad de la tabla de vehículos.
T08	Bucket S3 (documentos de registro)	D	Un actor con permisos de eliminación sobre el bucket puede borrar los documentos de registro, lo que ocasiona referencias rotas en DescribeVehicle y reduce la disponibilidad de los documentos de registro.
T09	API Gateway (las cuatro operaciones)	E	Un usuario de solo consulta, bajo un ámbito de autorización compartido, puede invocar operaciones administrativas, lo que ocasiona acciones no autorizadas y reduce el control de autorización del registro de vehículos.
T10	Función Lambda	E	Un actor que invoca Lambda directamente puede omitir la autenticación, lo que ocasiona ejecución de operaciones sin autenticarse y reduce el control de autorización de la función de registro.
T11	Usuario (sesión / token de Cognito)	S	Un actor que roba el token de sesión de un usuario legítimo puede suplantarlo ante el API Gateway, lo que ocasiona operaciones ejecutadas bajo identidad ajena y reduce la autenticidad de las solicitudes de registro.
T12	Tabla DynamoDB (acceso directo, fuera de la API)	R	Un administrador con acceso directo a la tabla puede modificar un registro y negarlo, lo que ocasiona pérdida de trazabilidad y reduce el no repudio del historial de cambios de la tabla de vehículos.

5. Priorización de riesgos

El riesgo inherente se calculó multiplicando la probabilidad por el impacto, ambos en una escala de 1 a 5. Según el resultado, el riesgo se clasifica en cuatro niveles: Bajo va de 1 a 4, Medio de 5 a 9, Alto de 10 a 15 y Crítico de 16 a 25. La justificación de cada valoración está en el archivo Riesgos_y_Controles.xlsx, dentro de la carpeta 04_Riesgos_y_Controles.

ID	Prob.	Impacto	Riesgo	Nivel	Estrategia
T01	3	4	12	Alto	Mitigar
T02	2	4	8	Medio	Mitigar
T03	1	3	3	Bajo	Aceptar (con control mínimo)
T04	3	3	9	Medio	Mitigar
T05	3	4	12	Alto	Mitigar

T06	3	3	9	Medio	Mitigar
T07	3	3	9	Medio	Mitigar / Transferir
T08	1	4	4	Bajo	Aceptar (con control compensatorio)
T09	4	5	20	Crítico	Mitigar (prioridad inmediata)
T10	2	5	10	Alto	Mitigar
T11	2	4	8	Medio	Mitigar
T12	2	4	8	Medio	Mitigar

La amenaza T09 quedó en riesgo Crítico y se trató como prioridad inmediata de mitigación. Esta amenaza ocurre porque un usuario con rol de solo consulta puede ejecutar operaciones como RegisterVehicle o DeregisterVehicle, ya que todo el sistema comparte un único ámbito de autorización. No es una hipótesis: es una falla de diseño que ya estaba confirmada por los propios supuestos del sistema, WWWO-02 y WWWO-18.

6. Controles propuestos

Para cada amenaza se seleccionaron controles de un catálogo de mitigaciones que va de M-001 a M-023. Este catálogo se tomó del material de clase y el equipo lo amplió. Para cada control se indica su tipo y el equipo responsable sugerido. El catálogo completo, con la relación entre cada control y su amenaza, está en la hoja "Catálogo_Mitigaciones" del archivo Riesgos_y_Control.es.xlsx.

ID	Controles (ID)	Tipo de control	Responsable sugerido
T01	M-001, M-006	Preventivo	Equipo de Seguridad/IAM
T02	M-007, M-012	Preventivo	Equipo de Infraestructura/DevOps
T03	M-001, M-013	Preventivo	Equipo de Backend
T04	M-004	Detectivo	Equipo de Backend/Cumplimiento
T05	M-002, M-011	Preventivo	Equipo de Backend
T06	M-003, M-022	Preventivo / Correctivo	Equipo de Backend
T07	M-008, M-009, M-020	Preventivo	Equipo de Infraestructura
T08	M-016, M-009	Preventivo / Detectivo	Equipo de Infraestructura
T09	M-010, M-011	Preventivo	Equipo de Arquitectura/Backend
T10	M-010, M-019	Preventivo	Equipo de Backend
T11	M-014, M-015	Preventivo	Equipo de Seguridad/IAM
T12	M-004, M-018	Detectivo	Equipo de Infraestructura

7. Riesgos residuales

Después de aplicar los controles propuestos, el riesgo residual baja en las 12 amenazas. La amenaza más crítica, T09, pasa de Crítico a Bajo una vez que se implementan ámbitos de autorización más específicos. Las amenazas T03 y T08 no necesitan controles adicionales fuertes: como su riesgo inherente ya era Bajo, se aceptaron con controles compensatorios de bajo costo.

ID	Riesgo inherente	Riesgo residual	Evidencia esperada
T01	Alto	Bajo	Certificado ACM activo y política de seguridad TLS/HSTS configurada
T02	Medio	Bajo	Política IAM de mínimo privilegio documentada y revisada
T03	Bajo	Muy bajo	Política de seguridad TLS 1.2+ y expiración corta de URL prefirmada
T04	Medio	Bajo	Logs de acceso de API Gateway y CloudTrail habilitados con retención definida
T05	Alto	Bajo	Pruebas de autorización por flota (un usuario no puede leer vehículos de otra flota)
T06	Medio	Bajo	Revisión de código que confirme ausencia de datos sensibles en logs
T07	Medio	Bajo-Medio	Usage plan de API Gateway y auto-scaling de DynamoDB configurados
T08	Bajo	Bajo	Versionado de S3 habilitado y política de bucket documentada
T09	Crítico	Bajo	Diseño de scopes documentado y pruebas de autorización negativas
T10	Alto	Bajo	Política de recursos de Lambda restringida al ARN del API Gateway y validación de JWT en código
T11	Medio	Bajo	MFA habilitado en Cognito y expiración corta de tokens
T12	Medio	Bajo-Medio	DynamoDB Streams y CloudTrail data events configurados

8. Conclusiones y reflexión del equipo

El proceso de threat modeling nos permitió pasar de un diagrama de arquitectura a 12 amenazas concretas, priorizadas por riesgo y con controles claros. El hallazgo más importante fue que la amenaza de mayor riesgo, T09, no depende de una vulnerabilidad técnica complicada, sino de una decisión de diseño que ya estaba documentada en los propios supuestos del sistema: las cuatro operaciones de la API comparten un único ámbito de autorización. Esto confirma lo que se vio en clase: las amenazas simples, basadas en el propio diseño, suelen ser más probables que las cadenas de explotación sofisticadas.

Seguir siempre la misma estructura para redactar las amenazas, con fuente, precondition, acción, impacto y activo, ayudó a mantener la trazabilidad entre el diagrama, los supuestos, las amenazas y los controles. Además, evitó que quedaran amenazas vagas o difíciles de accionar.

Como reflexión del equipo, el reto más grande fue no ver las amenazas "a través de la mitigación", es decir, no descartar de entrada escenarios que parecían ya cubiertos por TLS o por IAM. El material de clase advierte sobre

este error. Separar primero la identificación de amenazas de la selección de controles nos ayudó a no subestimar el número de escenarios posibles, sobre todo en las categorías de Denial of Service y Elevation of Privilege, que al principio parecían menos evidentes que Spoofing o Tampering.

Para el futuro, el equipo considera que vale la pena extender este mismo ejercicio a las demás funciones del sistema de registro de vehículos conectados que quedaron fuera de este laboratorio: el registro de conductores, la telemetría, los diagnósticos y la detección de anomalías.